

Port Scanning and User Enumeration

Ethical Hacking Lab 2 - Mission Red Team

Raliegth Barnett | Cybersecurity & Networking Portfolio

Portfolio Case Study - Detailed Project Oversight and Completion Record

All offensive-security activities described in this document were performed in authorized, isolated academic laboratory environments.

1. Project Overview

An attack-surface discovery project that moved from host discovery and fast scanning to full-range SYN scanning, version and OS detection, SMB user enumeration, legacy null-session analysis, and Bash-based ping-sweep automation.

Project Field	Details
Role and Responsibility	Red-team reconnaissance operator, script author, analyst, and report writer.
Environment and Tools	Kali Linux, Metasploitable 2, Nmap, netdiscover, arp-scan, netcat, rpcclient, enum4linux, Bash.
Completion Status	Completed - documented, tested, and included in the master portfolio.
Portfolio Classification	Academic / personal technical project with recruiter-facing case-study documentation.

2. Project Objectives and Success Criteria

- Discover the target and inventory all exposed TCP services.
- Compare fast and full-port scans.
- Validate banners and operating-system details.
- Enumerate SMB users, shares, groups, and server information.
- Automate live-host discovery across a /24 subnet.

3. Project Oversight and Execution Process

3.1 Planning and Scope

Defined the authorized environment, project goal, tools, expected outputs, and safety limitations.

3.2 Implementation

Executed the technical tasks and maintained notes, commands, screenshots, and configuration evidence.

3.3 Validation and Testing

Compared actual output with objectives, confirmed repeatable behavior, and collected proof of completion.

3.4 Analysis and Reporting

Converted technical evidence into findings, defensive interpretation, limitations, and recommendations.

3.5 Portfolio Finalization

Prepared a recruiter-friendly summary, detailed case study, screenshots, source report, and public-release guidance.

4. Technical Methodology

1. Discovered hosts using netdiscover or arp-scan.
2. Ran Nmap fast scans and complete 65,535-port SYN scans.
3. Used service/version detection, OS fingerprinting, and banner grabbing.
4. Enumerated SMB accounts with NSE, rpcclient, and enum4linux.
5. Tested anonymous/null-session exposure in the authorized lab.
6. Developed a parallel Bash ping-sweep script.

5. Deliverables and Completion Evidence

Deliverable	Status	Evidence
Technical implementation / lab execution	Complete	Commands, configurations, code, or forensic workflow documented.
Testing and validation	Complete	Results and screenshots included below and in the original report.
Detailed project documentation	Complete	This case-study document and README.
Source/original evidence	Complete	Original report or source files stored in this project folder.
Recruiter-ready description	Complete	Summary and skills section included.
Public publishing review	Required before posting	Remove credentials, personal identifiers, confidential case data, and unnecessary target details.

6. Results and Outcomes

- Full scanning revealed substantially more services than the quick profile.
- Enumeration exposed service accounts, shares, workgroup details, and weak legacy configuration.

- The parallel script reduced /24 discovery time compared with a sequential loop.

7. Challenges, Decisions, and Lessons Learned

- Balancing scan speed with reliability and detection risk.
- Interpreting service banners that may be misleading or intentionally vulnerable.

8. Screenshots and Supporting Evidence

A fast port scan was executed to quickly enumerate the most common services:

```
nmap -F 192.168.56.101
```

Q: How many open ports did you discover?

A: The fast scan reported 3 open ports within the top-100 scanned range (expanded to 7 when the full fast-scan profile completed: 21, 22, 23, 25, 80, 139, 445).

Q: What critical services are running?

A: FTP (21), SSH (22), Telnet (23), SMTP (25), HTTP (80), NetBIOS-SSN (139), and Microsoft-DS/SMB (445).

Q: Intelligence suggests some services may be hidden. What is the next step?

A: Perform a full TCP SYN stealth scan across all 65,535 ports so that nothing above the default top-1000 range is missed.

3. Full Scan – Stealth Mode

To avoid triggering the IDS/IPS a SYN (half-open) scan across the entire TCP range was performed:

```
sudo nmap -sS -p- -T4 192.168.56.101
```

Q: How does the output differ from the fast scan?

A: The stealth scan revealed significantly more open ports, including high-risk legacy services such as RPC, the r-services (rlogin/rsh/rexec), MySQL, PostgreSQL, IRC, distccd and Tomcat, which were all missed by the fast scan.

Q: Did you find any additional open ports or services?

A: Yes. Additional services identified: RPC/portmapper (111), NFS (2049), r-services (512, 513, 514), MySQL (3306), PostgreSQL (5432), distccd (3632), VNC (5900), X11 (6000), IRC/UnrealIRCd (6667), Tomcat (8180), AJP13 (8009), and Bindshell (1524).

Pro tip applied: the scan rate was tuned with -T4 to balance speed against detection; --min-rate/--max-rate can be used for further tuning if the Blue Team is aggressive.

4. Service Recon with OS Detection

Version detection and OS fingerprinting were performed to pierce any mislabeled banners:

```
sudo nmap -sV -O -p- 192.168.56.101
# Banner grabbing
nc -v 192.168.56.101 21
nc -v 192.168.56.101 6667
telnet 192.168.56.101 25
```

Fast scan versus complete scan findings.

- queryuser on msfadmin showed membership in the sudoers group – this account effectively has root access.
- netshareenum exposed writable shares: tmp (read/write), opt, IPC\$, ADMIN\$, and print\$.
- srvinfo reported the host as a Samba 3.0.20-Debian server, workgroup WORKGROUP, running on platform 500 (Unix).

7. Special Ops Task – Ping Sweep Automation

The following bash script performs a parallelised ping sweep across a /24 network and reports only live hosts. It uses background jobs so that all 254 probes run concurrently instead of sequentially, which makes it roughly 100× faster than a serial loop.

```
#!/bin/bash
# ping_sweep.sh – fast /24 host discovery
# Usage: ./ping_sweep.sh 192.168.56

if [ -z "$1" ]; then
    echo "Usage: $0 <network-prefix> e.g. $0 192.168.56"
    exit 1
fi

NET="$1"
echo "[*] Sweeping $NET.0/24 for live hosts..."
START=$(date +%s)

for ip in $(seq 1 254); do
    (
        if ping -c 1 -W 1 "$NET.$ip" &>/dev/null; then
            # Resolve hostname if DNS is available
            HOST=$(getent hosts "$NET.$ip" | awk '{print $2}')
            printf "[+] %-15s UP   %s\n" "$NET.$ip" "${HOST:-unknown}"
        fi
    ) &
done
wait

END=$(date +%s)
echo "[*] Sweep finished in $((END-START)) seconds."
```

Sample output:

```
[*] Sweeping 192.168.56.0/24 for live hosts...
[+] 192.168.56.1   UP   gateway
[+] 192.168.56.100 UP   kali
[+] 192.168.56.101 UP   metasploitable
[*] Sweep finished in 3 seconds.
```

Parallel Bash ping-sweep automation.

9. Skills Demonstrated

Nmap, network discovery, service enumeration, SMB/RPC, rpcclient, enum4linux, Bash scripting, attack-surface analysis.

10. Recommendations and Future Improvements

- Add XML/grepable output parsing and automatic findings classification.
- Include packet captures to compare scan signatures.

11. Portfolio and Resume Presentation

Port Scanning and User Enumeration - An attack-surface discovery project that moved from host discovery and fast scanning to full-range SYN scanning, version and OS detection, SMB user enumeration, legacy null-session analysis, and Bash-based ping-sweep automation.

Recommended repository contents: README.md, Documentation/, Evidence/, Source/ or Original_Report/, and a clear authorization/privacy notice.

12. Completion Statement

This project is considered complete for portfolio use because the scope, implementation process, testing evidence, results, skills, limitations, and future improvements are documented. Before public release, sensitive data must be reviewed and removed.